

Pen Testing (Web Applications + Bug Bounty)

Complete Assignment + Viva Notes

1. Penetration Testing vs Vulnerability Assessment

Simple Definition: Penetration testing simulates real cyber attacks while vulnerability assessment finds weaknesses.

Full Explanation:

- Pen testing is performed by ethical hackers.
- Vulnerability assessment identifies security weaknesses.
- Pen testing exploits vulnerabilities.
- Both methods improve security.

Point-Wise Answer:

- Vulnerability assessment identifies weaknesses.
- Penetration testing simulates attacks.
- Pen testing is more detailed.
- Used to improve cyber security.

Viva Questions & Answers:

Q. What is penetration testing?

A. Security testing using ethical hacking.

Q. What is vulnerability assessment?

A. Finding security weaknesses.

Q. Which is more detailed?

A. Penetration testing.

2. OWASP and OWASP Top 10

Simple Definition: OWASP is a non-profit organization for web application security.

Full Explanation:

- OWASP stands for Open Web Application Security Project.
- OWASP Top 10 lists major web vulnerabilities.
- Helps developers secure applications.
- Provides security awareness.

Point-Wise Answer:

- OWASP improves web security.

- Lists common vulnerabilities.
- Examples include SQL Injection and XSS.

Viva Questions & Answers:

Q. What is OWASP?

A. Organization for web security.

Q. What is SQL Injection?

A. Database attack using SQL queries.

Q. What is XSS?

A. Script injection attack.

3. Bug Bounty Program

Simple Definition: Bug bounty programs reward ethical hackers for finding vulnerabilities.

Full Explanation:

- Companies invite ethical hackers to test systems.
- Researchers report vulnerabilities responsibly.
- Organizations provide rewards.
- Improves application security.

Point-Wise Answer:

- Finds hidden vulnerabilities.
- Improves security.
- Reduces cyber attacks.
- Provides real-world testing.

Viva Questions & Answers:

Q. What is a bug bounty program?

A. Program rewarding ethical hackers.

Q. Who participates?

A. Security researchers.

Q. Why are bug bounties important?

A. They improve security.

4. Reconnaissance in Penetration Testing

Simple Definition: Reconnaissance is collecting information about a target.

Full Explanation:

- First phase of penetration testing.

- Collects IPs, domains, and ports.
- Can be passive or active.
- Improves testing accuracy.

Point-Wise Answer:

- Collects target information.
- Finds vulnerabilities.
- Uses tools like Nmap.
- Improves penetration testing.

Viva Questions & Answers:

Q. What is reconnaissance?

A. Information gathering process.

Q. What is passive reconnaissance?

A. Collecting information without interaction.

Q. Name one reconnaissance tool.

A. Nmap.

5. SQL Injection (SQLi)

Simple Definition: SQL Injection is a database attack using malicious SQL queries.

Full Explanation:

- Attackers inject SQL code into forms.
- Weak input validation causes SQLi.
- Can bypass login systems.
- Can steal database data.

Point-Wise Answer:

- Targets databases.
- Uses malicious SQL queries.
- Can bypass authentication.
- Prevented using prepared statements.

Viva Questions & Answers:

Q. What is SQL Injection?

A. Database attack using SQL queries.

Q. What is the target?

A. Database systems.

Q. How to prevent SQL Injection?

A. Input validation.

6. Cross-Site Scripting (XSS)

Simple Definition: XSS is a vulnerability where attackers inject malicious scripts into websites.

Full Explanation:

- Attackers inject JavaScript code.
- Scripts run in victim browsers.
- Stored XSS is saved on servers.
- Reflected XSS appears temporarily.

Point-Wise Answer:

- XSS injects malicious scripts.
- Stored XSS is more dangerous.
- Can steal cookies.
- Prevented using input validation.

Viva Questions & Answers:

Q. What is XSS?

A. Script injection vulnerability.

Q. Which language is mostly used?

A. JavaScript.

Q. Which is more dangerous?

A. Stored XSS.